

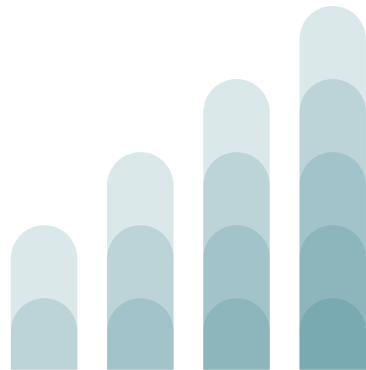
INSTITUTO FEDERAL DE
EDUCAÇÃO, CIÊNCIA E TECNOLOGIA
SÃO PAULO
Campus Campos do Jordão

Gestão de TI

Framework COBIT

Introdução, Princípios, Domínios e Processos.

Professor Mestre Igor de Moraes Sampaio
igor.sampaio@ifsp.edu.br





Introdução





O que é o COBIT?

COBIT (Control Objectives for Information and Related Technologies / Controle de Objetivos para Informação e Tecnologias Relacionadas) é um framework de governança e gestão de TI / informação e tecnologia (I&T) desenvolvido pela ISACA (Information Systems Audit and Control Association / Associação de Auditoria e Controle de Sistemas de Informação).

Ele fornece um modelo para ajudar conselhos, gestores, auditores e equipes de TI a garantir que a I&T suporte os objetivos do negócio, entregue valor, gerencie riscos e use recursos de forma eficiente.



O que é o COBIT?

Ele reúne diretrizes de gerenciamento e controle dos elementos que compõem a governança, que são:

- Processos;
- Práticas;
- Modelos;
- Princípios;
- Pessoas;
- Informações;
- Infraestrutura;
- Aplicativos;
- Estruturas organizacionais.

A HISTORICAL TIMELINE

The COBIT® Framework

COBIT® 2019



1996

ISACA released the first edition of COBIT framework.



2000

A third edition of COBIT, with new Management Guidelines, was published.

2005

COBIT 4.0 becomes the fourth edition in the COBIT series of releases.



2012

COBIT 5 integrated the COBIT 4.1, Val IT 2.0 and Risk IT frameworks, and drew from ISACA's IT Assurance Framework (ITAF) and the Business Model for Information Security (BMIS). COBIT 5 also coordinated with frameworks and standards such as ITIL, ISO, PMBOK, PRINCE2 and TOGAF.



2018

ISACA publishes COBIT 2019, an update that adds design factors and focus areas to make it more practical and customizable.

1998

The debut of the second edition of COBIT added Control to its framework.

2003

ISACA created an online version of the third edition of COBIT.



2007

COBIT upgraded to version 4.1.

1995

1995

Windows 95, Java, and HTML 2.0 (first formal html standard) debuted, as did Amazon.com, craigslist.com, match.com and ebay.com

1997

Original wireless LAN standard (IEEE 802.11) released, DVD technology appeared, and Google.com registered as domain—incorporating a year later and launching in 1999.

2000

2002

U.S. Sarbanes-Oxley law revolutionized corporate recordkeeping and retention standards, leading to new IT regulatory requirements.

2005

2003

Third WiFi standard created proliferation of "hotspots" as Skype, LinkedIn and WordPress started up. U.S. CAN-SPAM Act became law.

2010

2007

Apple iPhone signaled move to touchscreen devices; Apple App Store went online one year later.

2006

Twitter founded and Google acquired YouTube.

2014

Internet of Things (IoT) technology standard ushered new wave of smart devices.

2015

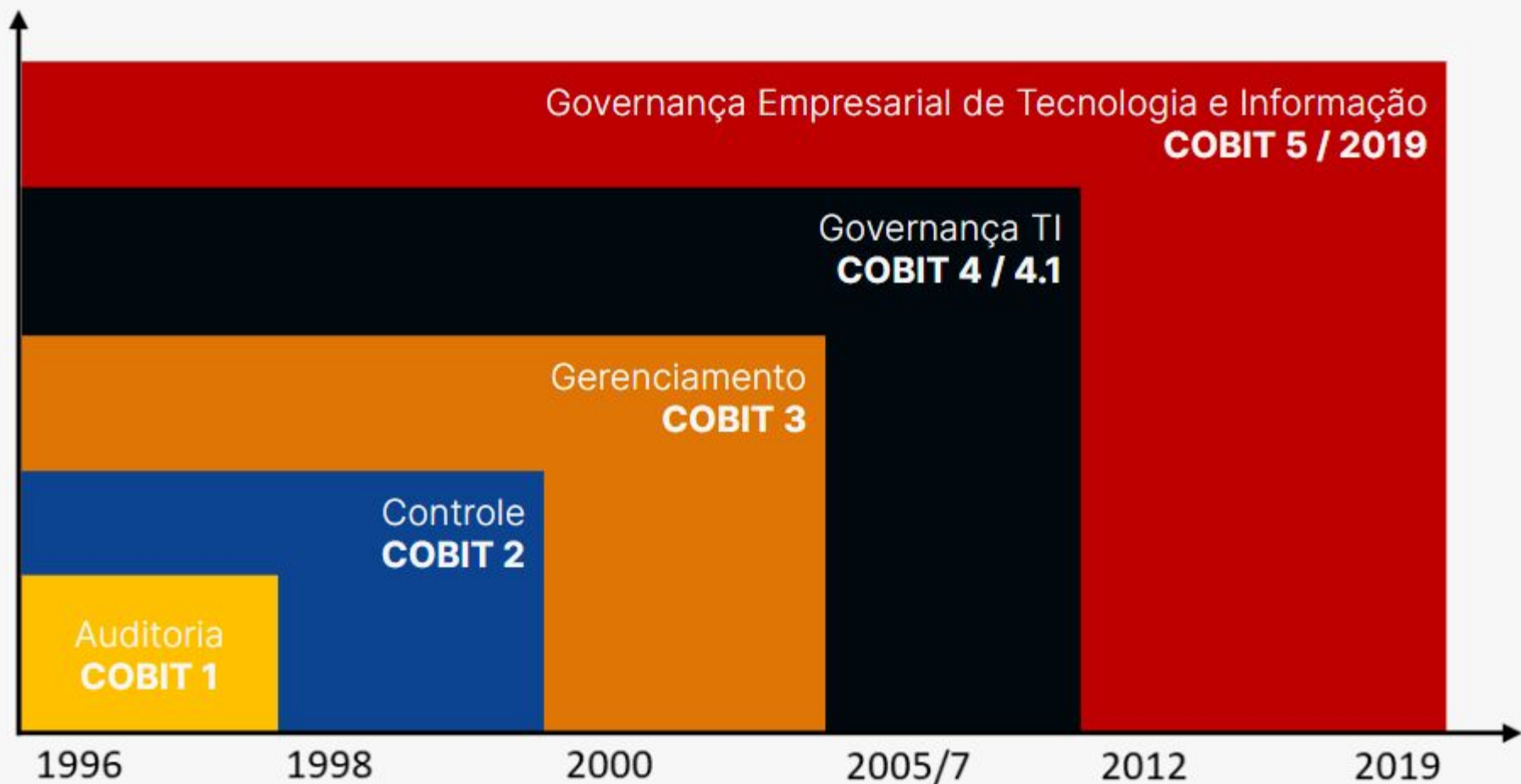
2016

ISACA acquired CMMI Institute and its business maturity and capability models, adding these resources to the ISACA/COBIT framework portfolio.

2012

Worldwide e-commerce tops \$1 trillion in sales.







Visão Geral



Componentes de um Sistema de Governança





Reference: COBIT® 2019 Framework: Basic Concepts: Governance Systems and Components, Figure 4.3

Componentes de um Sistema de Governança



Componentes do Sistema de Governança COBIT

O COBIT organiza a TI em componentes interligados, chamados de componentes do sistema de governança:

Componente	Função
Processos	Descrevem práticas e atividades para atingir objetivos
Estruturas organizacionais	Define papéis e responsabilidades
Fluxos de informação	Gestão da informação como ativo
Cultura, ética e comportamento	Incentiva a conduta esperada
Pessoas, habilidades e competências	Gestão de talentos
Políticas e procedimentos	Direcionam ações e decisões
Serviços, infraestrutura e aplicações	Elementos técnicos de apoio



Componentes do Sistema de Governança COBIT

Os componentes podem ser genéricos ou variações de componentes genéricos:

- Componentes genéricos fazem parte do modelo central do COBIT e são aplicáveis em qualquer situação. No entanto, por serem genéricos, normalmente precisam ser adaptados antes de serem implementados na prática.
- Variações são versões adaptadas dos componentes genéricos, criadas para atender a um propósito específico ou a um contexto particular, como segurança da informação, DevOps ou uma regulamentação específica.



Áreas de Foco do COBIT





Áreas de Foco do COBIT

- Uma Área de Foco descreve um determinado tema, domínio ou questão de governança que pode ser abordado por uma coleção de objetivos de governança e gestão e seus componentes.
- As Áreas de Foco podem conter uma combinação de componentes de governança genéricos e variantes.
- O número de Áreas de Foco é praticamente ilimitado. Isso é o que torna o COBIT aberto e flexível. Novas Áreas de Foco podem ser adicionadas conforme necessário ou à medida que especialistas e profissionais contribuem.



Exemplos de Áreas de Foco do COBIT

- Pequenas e médias empresas
- Segurança da Informação
- Risco
- DevOps (“Development” e “Operations”)
- Segurança Cibernética
- Privacidade de Dados
- Transformação Digital
- Computação em Nuvem



Fatores de Design do COBIT



COBIT 2019 Design Factors

Enterprise
Strategy

Enterprise
Goals

Risk Profile

I&T-Related
Issues

Threat
Landscape

Compliance
Requirements

Role of IT

Sourcing
Model
for IT

IT
Implementation
Methods

Technology
Adoption
Strategy

Enterprise
Size

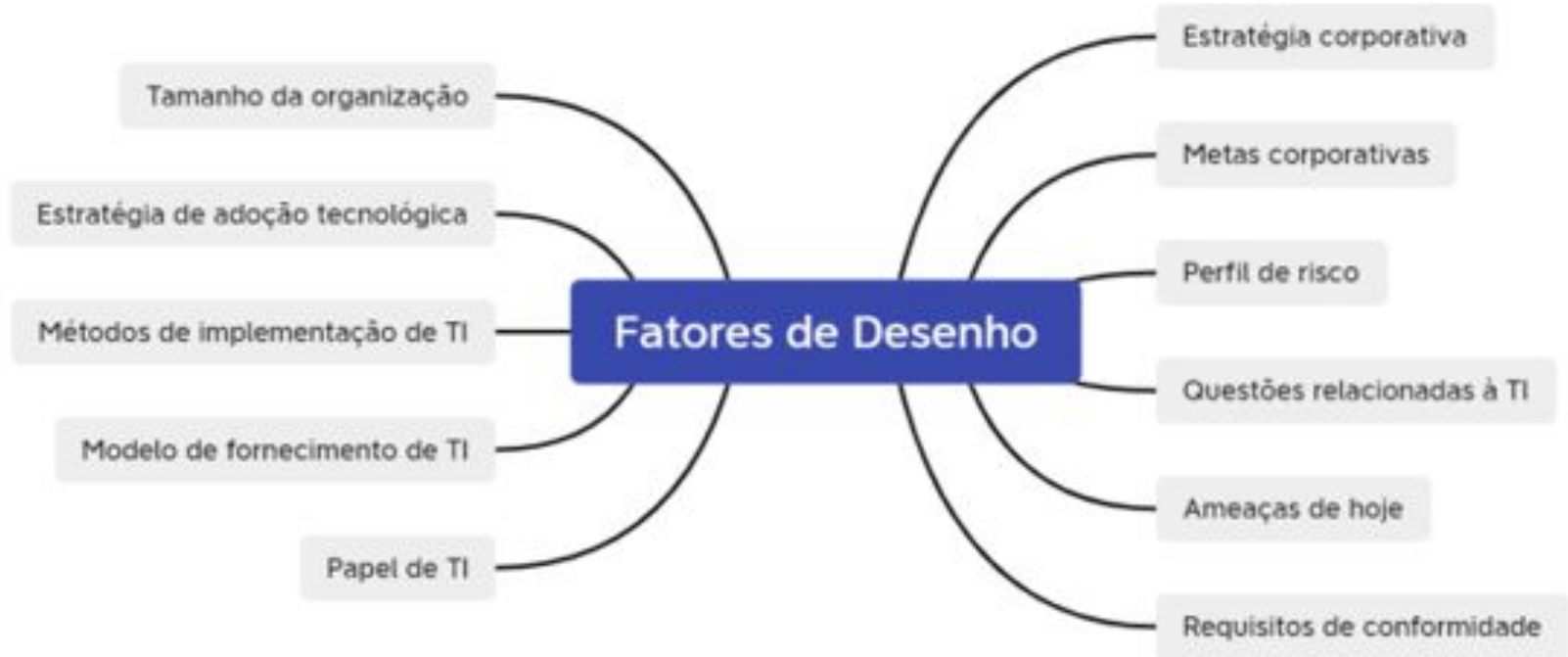
Future Factors

Fatores de Design do COBIT



Fatores de Design do COBIT

- Os fatores de desenho influenciam o tipo de sistema de governança de TI que a organização precisa. Em outras palavras, são parâmetros para ajudar a compor o sistema.
- Os fatores de desenho são previamente definidos no COBIT 2019, totalizando 11 tópicos.



Fatores de Design do COBIT



Fatores de Design do COBIT

- **Enterprise Strategy (Estratégia da Empresa)**
 - A estratégia da organização influencia **como a TI deve ser organizada**.
 - Exemplo: Se a empresa foca em inovação, a TI precisa estar orientada para pesquisa e adoção de novas tecnologias. Se o foco for eficiência operacional, a TI deve buscar automação e redução de custos.
- **Enterprise Goals (Objetivos da Empresa)**
 - São as **metas de negócio** da organização.
 - Esses objetivos ajudam a priorizar os processos de governança.
 - Exemplo: se o objetivo é expansão internacional, a TI precisa apoiar operações globais (idiomas, fusos, legislações locais).
- **Risk Profile (Perfil de Risco)**
 - Define os riscos mais relevantes para a organização (financeiros, tecnológicos, regulatórios, reputacionais).
 - Exemplo: Uma empresa financeira terá um perfil de risco alto em segurança da informação, enquanto uma indústria pode ter maior risco em paradas de produção.



Fatores de Design do COBIT

- I&T-Related Issues (Problemas Relacionados a Informação e Tecnologia)
 - Problemas atuais ou recorrentes relacionados à TI que impactam a organização.
 - Exemplo: sistemas instáveis, falhas de integração, incidentes de segurança, baixa adoção de novas ferramentas.
- Threat Landscape (Cenário de Ameaças)
 - Analisa o ambiente externo em termos de ameaças tecnológicas e de segurança.
 - Exemplo: aumento de ataques de ransomware, novas regulamentações de privacidade, evolução de malware.
- Compliance Requirements (Requisitos de Conformidade)
 - Obrigações legais, regulatórias e contratuais que a empresa deve seguir.
 - Exemplo: LGPD no Brasil, GDPR na Europa, PCI-DSS para cartões de crédito, ISO 27001 para segurança da informação.
- Role of IT (Papel da TI)
 - Determina se a TI é apenas suporte operacional, parceira estratégica ou motor de inovação dentro da empresa.
 - Exemplo: em um banco digital, a TI é o coração do negócio; em uma fábrica tradicional, pode ser mais suporte.



Fatores de Design do COBIT

- **Sourcing Model for IT (Modelo de Fornecimento de TI)**
 - Define como a TI é obtida: interna, terceirizada, em nuvem, híbrida.
 - Exemplo: uma empresa pode manter servidores internos por segurança, ou terceirizar infraestrutura em nuvem para reduzir custos.
- **IT Implementation Methods (Métodos de Implementação de TI)**
 - Refere-se às abordagens usadas na entrega de soluções de TI.
 - Exemplo: metodologias Ágeis (Scrum, Kanban), DevOps, ou métodos tradicionais em cascata (Waterfall).
- **Technology Adoption Strategy (Estratégia de Adoção de Tecnologia)**
 - Mostra a postura da organização diante de novas tecnologias.
 - Pode ser:
 - Inovadora (early adopter): adota rápido tecnologias novas.
 - Moderada: espera estabilidade para adotar.
 - Conservadora: só adota quando é padrão consolidado.
- **Enterprise Size (Tamanho da Empresa)**
 - O porte da organização (pequena, média, grande) influencia a governança.
 - Exemplo: uma multinacional terá processos formais e complexos de TI; uma startup pode usar controles mais simples e flexíveis.

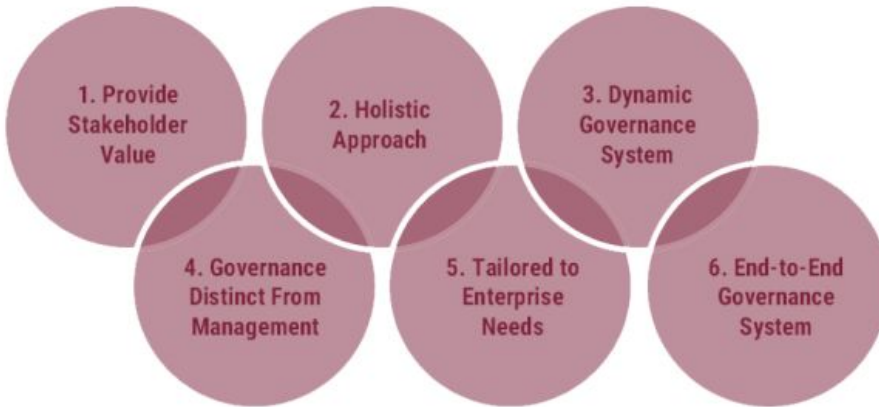


Princípios do COBIT

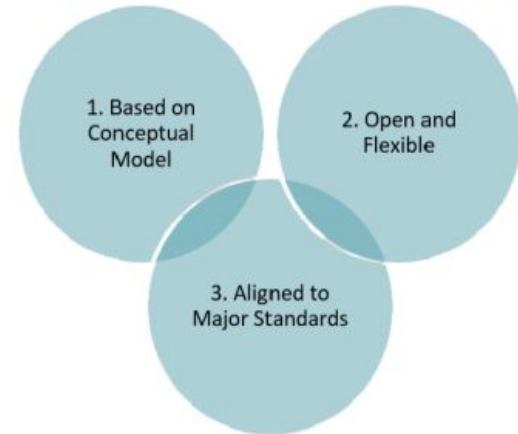


COBIT 2019

PRINCIPLES Governance System



PRINCIPLES Governance Framework



Princípios



Princípios do COBIT 2019

O COBIT 2019 é guiado por 6 princípios indicados para um Sistema de Governança.

1. Provide Stakeholder Value

- Gerar valor para as partes interessadas
 - Entrega benefícios e valor para todas as partes interessadas.

2. Holistic Approach

- Abordagem holística
 - Considera todos os fatores que afetam a governança.

3. Dynamic Governance System

- Sistema de governança dinâmico
 - Capaz de evoluir o sistema de governança ao longo do tempo.



Princípios do COBIT 2019

O COBIT 2019 é guiado por 6 princípios indicados para um Sistema de Governança.

4. Governance Distinct From Management

- Governança distinta da gestão
 - Diferencia claramente as responsabilidades de decisão estratégica (governança) das de execução operacional (gestão).

5. Tailored to Enterprise Needs

- Personalizado conforme as necessidades da organização
 - Adapta o sistema de governança à estratégia, tamanho, cultura e necessidades específicas da organização.

6. End-to-End Governance System

- Sistema de governança de ponta a ponta
 - Integra a governança em todas as áreas, funções e níveis da organização.



Princípios do COBIT 2019

O COBIT 2019 é guiado por 3 princípios para uma Framework de Governança.

1. Based on Conceptual Model
 - a. Baseado em modelo conceitual
2. Open and Flexible
 - a. Aberto e flexível
3. Aligned to Major Standards
 - a. Alinhado aos principais padrões



Domínios do COBIT

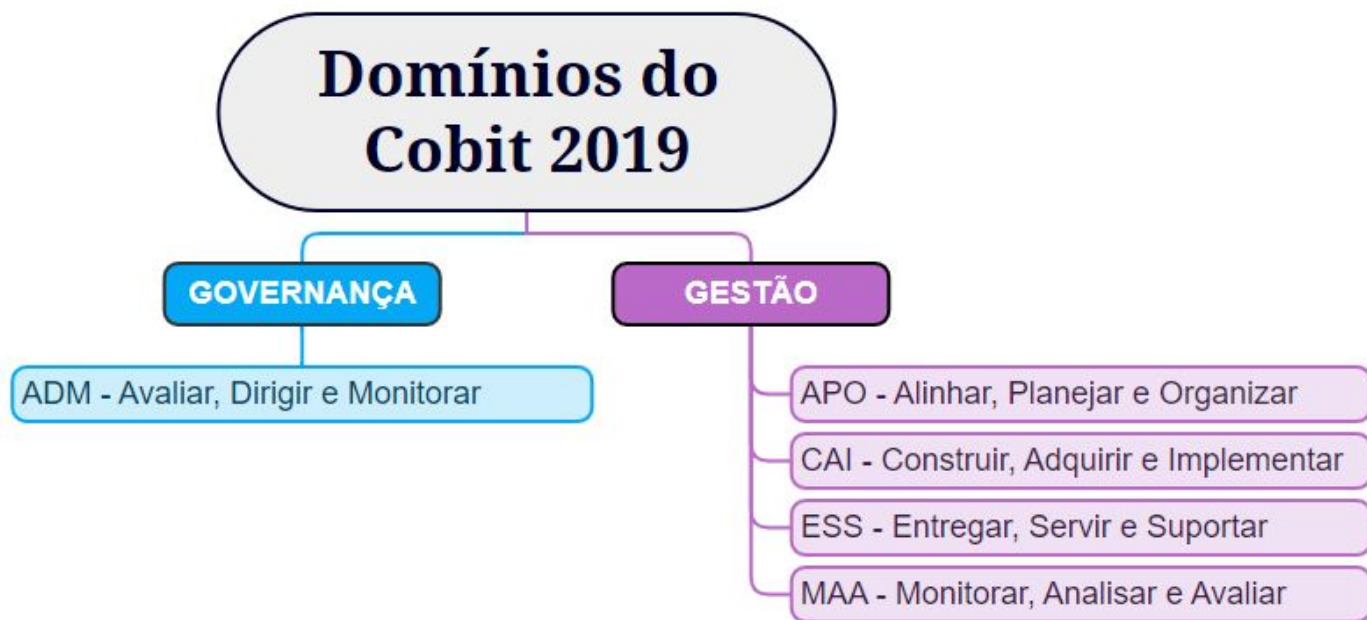




Domínios do COBIT

Domínios do COBIT (COBIT 2019)

Os processos do COBIT são organizados em 5 domínios principais, que cobrem toda a área de TI:

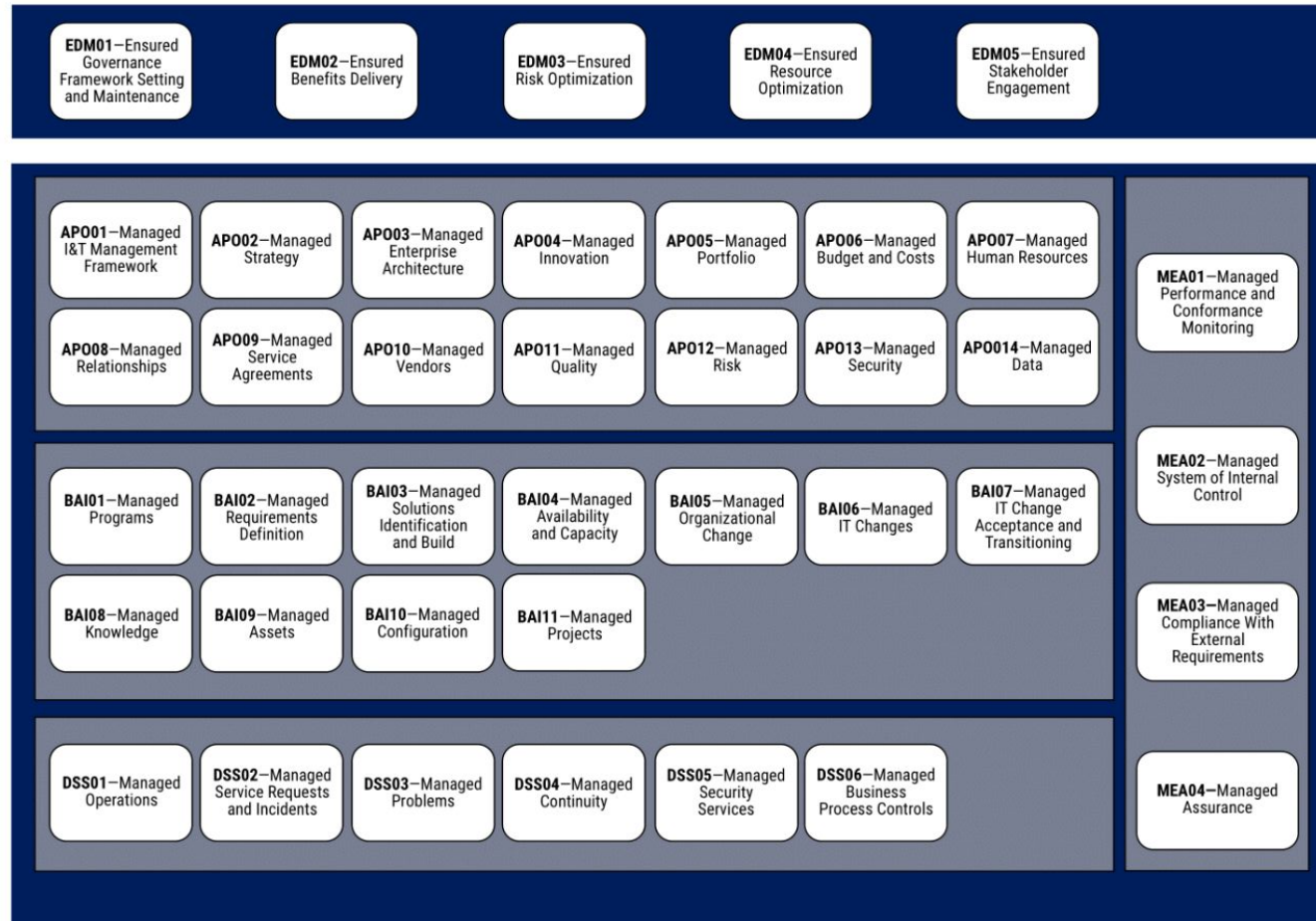




Processos do COBIT



Figure 4.2
COBIT Core Model



ADM – Avaliar, Dirigir e Monitorar

Este é o único domínio de governança, que possui 5 objetivos.



APO – Alinhar, Planejar e Organizar

Este domínio possui 14 objetivos.



CAI – Construir, Adquirir e Implementar

Este domínio possui 11 objetivos.



ESS – Entregar, Servir e Suportar

Este domínio possui 6 objetivos.

Entregar, Servir e Suportar (ESS)

O

Gerenciar Operações

S

Gerenciar Solicitações de Serviço e Incidentes

P

Gerenciar Problemas

C

Gerenciar Continuidade

S

Gerenciar Serviços de Segurança

C

Gerenciar Controles de Processo de Negócio

MAA – Monitorar, Analisar e Avaliar

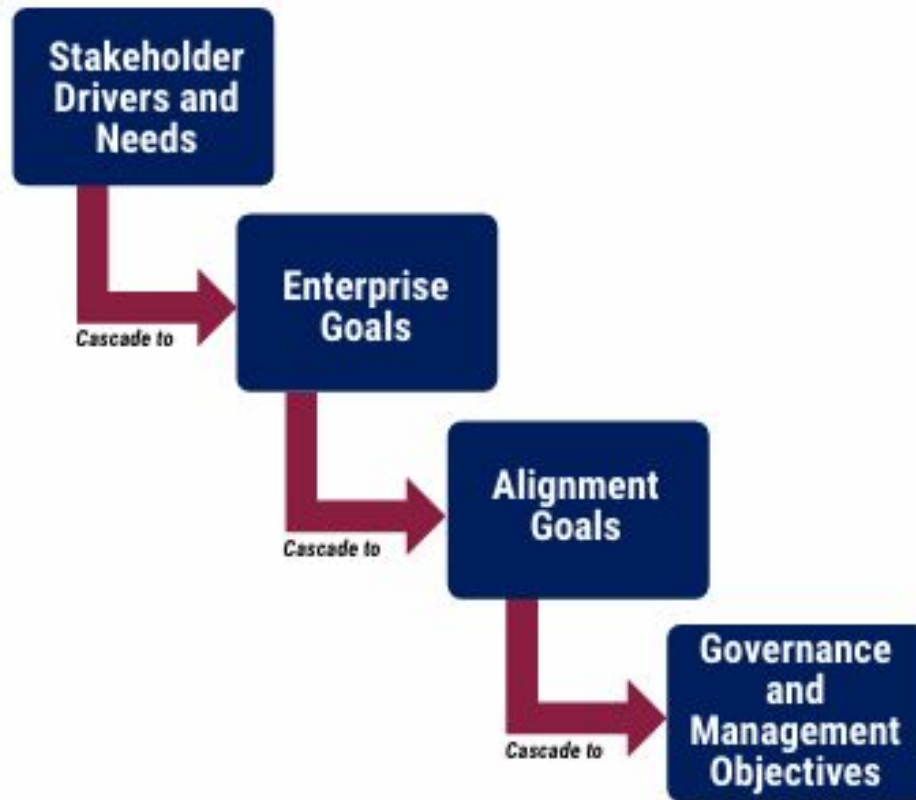
Este domínio possui 4 objetivos.





Cascata de Objetivos do COBIT





Cascata de Objetivos do COBIT



Cascata de Objetivos do COBIT

- A Cascata de Objetivos é um mecanismo do COBIT 2019 que converte as necessidades das partes interessadas em objetivos específicos de governança e gestão, garantindo que toda a TI e seus processos estejam alinhados com a estratégia do negócio.



Cascata de Objetivos do COBIT

- Stakeholder Drivers and Needs (Motivações e Necessidades das Partes Interessadas)
 - Representa os desejos, preocupações e expectativas de stakeholders (acionistas, clientes, sociedade, reguladores, colaboradores etc.). Exemplo:
 - Um cliente quer maior privacidade de dados, investidores desejam aumento de lucro, órgãos reguladores exigem conformidade legal.
 - São a base de tudo, pois as empresas existem para atender essas necessidades.
- Enterprise Goals (Objetivos da Organização)
 - São os objetivos de negócio que a empresa define para atender às necessidades dos stakeholders. Exemplos:
 - Aumentar a receita em 15% ao ano.
 - Garantir conformidade com a LGPD.
 - Melhorar a satisfação do cliente.
 - Traduzem as necessidades dos stakeholders em metas de negócio mensuráveis.



Cascata de Objetivos do COBIT

- Alignment Goals (Objetivos de Alinhamento)
 - São objetivos que traduzem os Enterprise Goals em termos de TI e governança corporativa, garantindo que a área de TI esteja alinhada ao negócio. Exemplos:
 - Garantir a disponibilidade e confiabilidade dos sistemas.
 - Proteger informações críticas contra acessos não autorizados.
 - Melhorar a integração entre processos de negócio e sistemas.
 - Fazem a ponte entre o negócio e a TI.
- Governance and Management Objectives (Objetivos de Governança e Gestão)
 - São objetivos específicos de governança e gestão de TI, derivados dos Alignment Goals. Exemplos:
 - Implementar controles de segurança para dados sensíveis.
 - Monitorar riscos relacionados a ciberataques.
 - Garantir que projetos de TI sejam entregues no prazo e no orçamento.
 - Traduzem os objetivos de negócio e alinhamento em práticas, processos e atividades concretas.



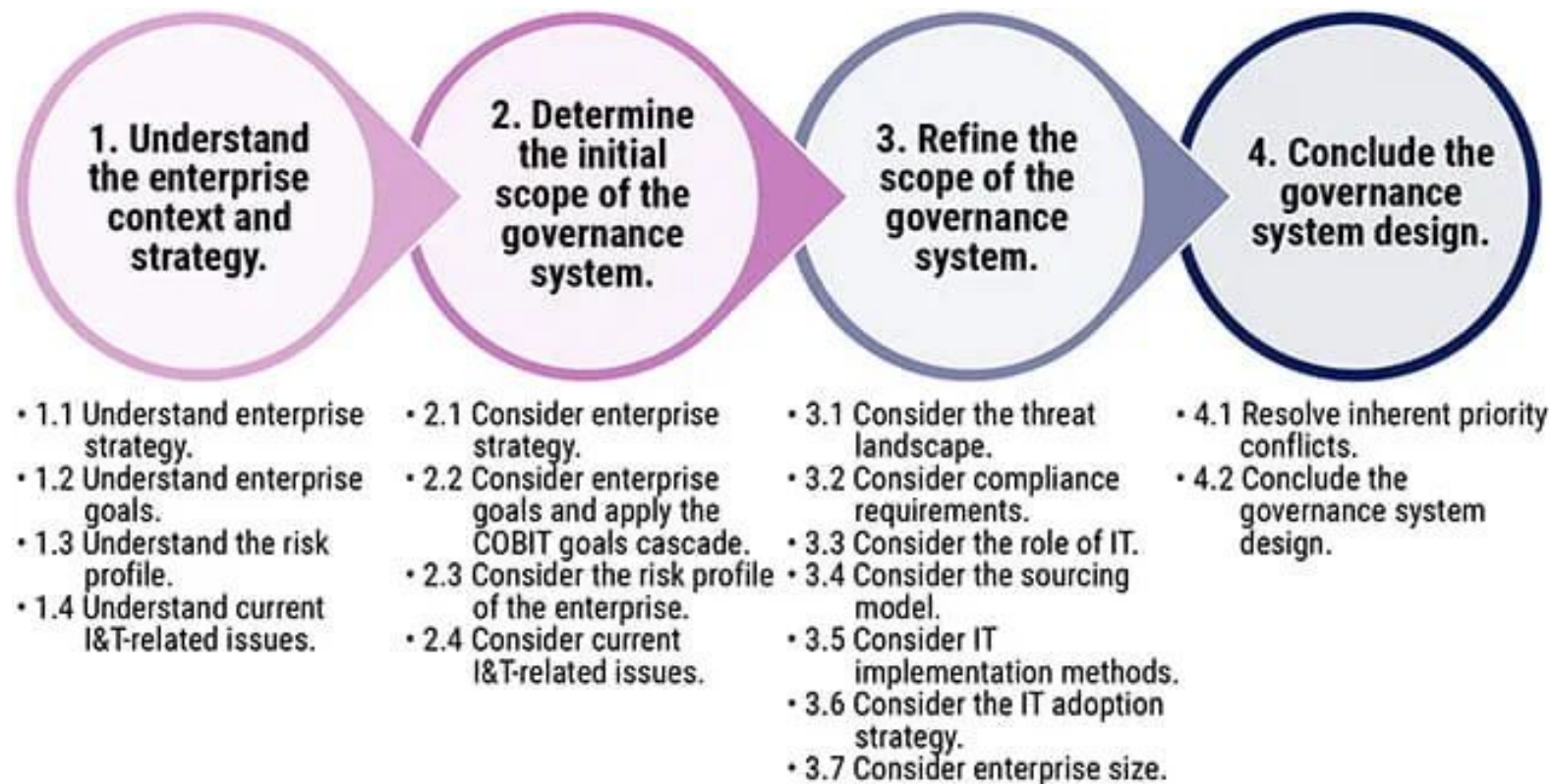
Cascata de Objetivos do COBIT - Resumo

- Stakeholders → expressam necessidades.
- Essas necessidades viram Objetivos da Empresa.
- Que se convertem em Objetivos de Alinhamento (TI + negócio).
- Que, por fim, são transformados em Objetivos de Governança e Gestão, com práticas e controles específicos.



Desenhando um Sistema de Governança Personalizado







Fluxo de Trabalho

- As diferentes etapas e fases do processo de design resultarão em recomendações para priorizar objetivos de governança e gestão ou componentes relacionados do sistema de governança, definindo níveis de capacidade-alvo ou adotando variantes específicas de um componente do sistema de governança.



Fluxo de Trabalho

- **Fase 1: Compreender o contexto e a estratégia da empresa.** Inclui entender a estratégia, os objetivos, o perfil de risco e os problemas atuais relacionados à I&T.
- **Fase 2: Determinar o escopo inicial do sistema de governança.** Envolve considerar a estratégia e os objetivos da empresa (aplicando o cascadeamento de objetivos do COBIT), o perfil de risco e os problemas atuais de I&T.
- **Fase 3: Refinar o escopo do sistema de governança.** Abrange a consideração do cenário de ameaças, requisitos de conformidade, papel da TI, modelo de sourcing, métodos de implementação de TI, estratégia de adoção de TI e tamanho da empresa.
- **Fase 4: Concluir o design do sistema de governança.** Foca na resolução de conflitos de prioridade inerentes e na finalização do design do sistema de governança.



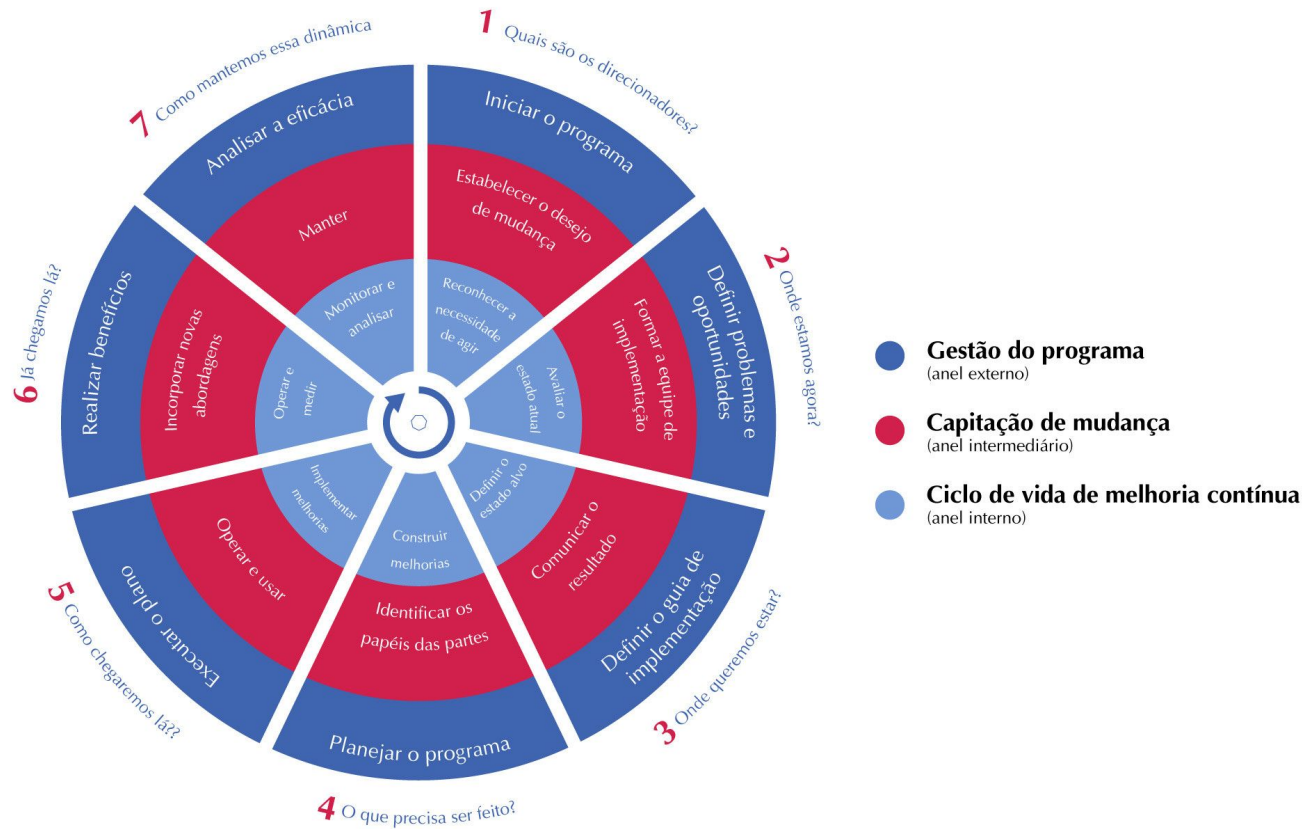
Implementação de um Sistema de Governança Personalizado





Implementação do COBIT

- O Guia de Implementação do COBIT® 2019 enfatiza uma visão corporativa ampla da governança de TI e tecnologia da informação (I&T).
- Ele reconhece que TI e tecnologia da informação são onipresentes nas organizações e que não é possível nem uma boa prática separar atividades de negócio das atividades relacionadas à TI.
- O guia de implementação é uma abordagem por fases com três perspectivas:
 - Melhoria Contínua (Continual Improvement)
 - Gestão de Programas (Program Management)
 - Capacitação para Mudança (Change Enablement)



Implementação de um Sistema de Governança Personalizado



Implementação do COBIT

- A **primeira fase**, identificando e aceitando a necessidade da implementação da governança. Desta forma, é possível verificar as fragilidades da organização e a alta direção considerar o momento e abordagem os quais propiciam a mudança.
- Na **segunda fase** ocorre a definição do escopo da implementação, através do mapeamento dos objetivos corporativos do COBIT em objetivos de TI e destes nos respectivos processos, definindo os riscos e demais considerações necessárias para identificar as áreas de alta prioridade.
- A **terceira fase** é voltada para definição do processo e sua respectiva meta de referência para a melhoria, com objetivo de encontrar falhas e avaliar soluções.
- Na **quarta fase** são planejadas ações práticas voltadas ao estudo de caso realizado, sendo as mesmas alinhadas a um plano de mudança e sua resolução para a implementação.
- A **quinta fase** considera que os planos de soluções deverão ser implementados de maneira prática e gerenciável, nesta fase também são definidas as métricas e os indicadores para que seja realizado o monitoramento com uso das metas do COBIT, visto que, a ideia é a garantia do entendimento da organização como um todo, de forma que seja entendido, atingido, mantido e medido.
- Já na **sexta fase** é considerada a operação de forma contínua e equilibrada dos novos habilitadores, na melhoria dos que já existem e no monitoramento dos benefícios almejados.
- Na **sétima fase**, são avaliadas todas as fases anteriores, é reforçada a necessidade de melhoria contínua e é nesta fase onde é possível identificar novos requisitos para a governança ou gestão de TI.



Atividade





Framework COBIT

1.

Implementação